sufficient information is assessed to fulfill the more narrowly tailored obligation to notify affected individuals.[281] Specifically, consistent with the GLBA, the final amendments are tailored to require that a covered institution's written policies and procedures must be reasonably designed to protect against unauthorized access to or use of customer information that could result in substantial harm or inconvenience to any customer, not merely all *sensitive* customer information.[282] Narrowing the service provider definition in a manner that would fail to cover the full scope of information that the GLBA requires to be covered in a covered institution's safeguarding policies and procedures, as would result from commenters' suggestion, would be inappropriate.[283] Further, we are also concerned that limiting the service provider definition to only address those persons or entities that receive, maintain, process, or are otherwise permitted access to sensitive customer information, as commenters suggest, would result in insufficient notification to covered institutions in the event of a breach at a service provider. The purpose of this service provider notification is to enable the covered institution to begin carrying out its

---

281 *See* discussion on Incident Response Program Including Customer Notification *supra* Section II.A.

282 *See* 17 CFR 248.30(a)(2)(iii). *See also* 15 U.S.C. 6801(b)(3) (mandating that the Commission shall establish appropriate standards for the financial institutions subject to its jurisdiction relating to administrative, technical, and physical safeguards "to protect against unauthorized access to or use of such records or information which could result in substantial harm or inconvenience to any customer.").

283 As discussed below, the definition of "customer information" we are adopting in these final amendments is intended to ensure that the standard for covered institutions' safeguards rule policies and procedures is consistent with the objectives of the GLBA, which focuses on protecting "nonpublic personal information" of those who are "customers" of financial institutions. See discussion on the Definition of Customer Information *infra* Section II.B.1. *See also* 17 CFR 248.30(d)(5) (defining "customer information"). In contrast, the definition of "sensitive customer information" that we are adopting is more narrowly tailored to only cover any component of customer information alone or in conjunction with any other information, the compromise of which could create a reasonably likely risk of substantial harm or inconvenience to an individual identified with the information. *See* 17 CFR 248.30(d)(9)(i). As discussed above, this definition is more narrowly tailored, and has been specifically calibrated to include types of information that, if exposed, could put affected individuals at a higher risk of suffering substantial harm or inconvenience through, for example, fraud or identity theft enabled by the unauthorized access to or use of the information. See discussion on the Definition of "Sensitive Customer Information" *supra* Section II.A.3.b. The narrower tailoring than is used in the "customer notification" definition is intended to protect customers by ensuring that they can take the necessary steps to minimize their exposure to these risks, while also being mindful of concerns of how a broader definition could increase the potential for over-notification of customers to address such risks. *See id*.

response program, which requires an assessment of the nature and scope of any incident involving unauthorized access to or use of customer information, not merely those involving sensitive customer information.[284] For these reasons, the Commission is adopting the service provider definition as modified.

The Commission also acknowledges the request to clarify the scope of what is included within the service provider definition, including "whether service providers would include financial counterparties such as brokers, clearing and settlement firms, and custodial banks." In alignment with the service provider definition we are adopting, covered institutions should make this determination based on the facts and circumstances about the substance of the relationship with the covered institution, rather than the form of the entity in question. Where financial counterparties receive, maintain, or otherwise are permitted access to customer information through the provision of services directly to the covered institution, they meet the service provider definition as adopted.

B. Scope of Safeguards Rule and Disposal Rule

1. Scope of Information Protected

We are adopting amendments to rule 248.30 that define the scope of information covered by the safeguards and disposal rules. These amendments will broaden and more closely align the scope of both rules by applying them to the information of not only a covered institution's own customers, but also the customers of other financial institutions that has been provided to the covered institution.[285] These amendments further specify that the rules also apply to customer

---

284 *See* final rule 248.30(b)(i). *See also* discussion on the assessment required by paragraph (a)(3) as to a covered institution's incident response program *supra* section II.A.1 above.

285 Final rule 248.30(a), (b), and (d)(5)(i). Regulation S-P defines "financial institution" generally to mean any institution the business of which is engaging in activities that are financial in nature or incidental to such financial activities as described in section 4(k) of the Bank Holding Company Act of 1956 (12 U.S.C. 1843(k)). 17 CFR 248.3(n).

information handled or maintained on behalf of the covered institution.[286] We are adopting these changes substantively as proposed, with changes to the structure of the rule in response to comments as discussed in more detail below.

Specifically, the amendments:

- Adopt a new definition of "customer information" defining the scope of information covered by both the safeguards and disposal rules. These amendments provide greater specificity regarding what constitutes customer information that must be protected under the safeguards rule. They also expand the scope of the disposal rule, which currently applies only to consumer information (defined as "consumer report information" in the current rule) so that it applies to both customer and consumer information.
- Provide that customer information protected under both the safeguards and disposal rules includes both customer information in the possession of a covered institution as well as customer information handled or maintained on its behalf.
- Provide that both customer and consumer information include information that pertains to individuals with whom the covered institution has a customer relationship, as well as to the customers of other financial institutions where such information has been provided to the covered institution. We are adopting this expansion as proposed but, as discussed below, have reorganized the rule provisions effectuating the change in response to comments.

Definition of Customer Information

[286] Final rule 248.30(d)(5)(i).

Currently, Regulation S-P's protections under the safeguards rule and disposal rule apply to different, and at times overlapping, sets of information.[287] Specifically, as required under the GLBA, the safeguards rule currently requires broker-dealers, investment companies, and registered investment advisers (but not transfer agents) to maintain written policies and procedures to protect "customer records and information,"[288] which is not defined in the GLBA or in Regulation S-P. The disposal rule requires every covered institution properly to dispose of "consumer report information," a different term, which Regulation S-P defines consistently with the FACT Act provisions.[289]

To align more closely the information protected by both rules, as proposed, we are amending rule 248.30 by replacing the term "customer records and information" in the safeguards rule with a newly defined term "customer information" and by adding customer information to the coverage of the disposal rule. For covered institutions other than transfer agents, the term "customer information" will mean, as proposed, "any record containing nonpublic personal information as defined in section 248.3(t) about a customer of a financial institution, whether in paper, electronic, or other form."[290]

---

287 *See* Disposal of Consumer Report Information, Investment Company Act Release No. 26685 (Dec. 2, 2004) [69 FR 71322 (Dec. 8, 2004)], at n.13 ("Disposal Rule Adopting Release").

288 *See* 17 CFR 248.30; 15 U.S.C. 6801(b)(1).

289 *See* 17 CFR 248.30(b)(2). Section 628(a)(1) of the FCRA directed the Commission to adopt rules requiring the proper disposal of "consumer information, or any compilation of consumer information, derived from consumer reports for a business purpose." 15 U.S.C. 1681w(a)(1). Regulation S-P currently uses the term "consumer report information," defined to mean a record in any form about an individual "that is a consumer report or is derived from a consumer report." 17 CFR 248.30(b)(1)(ii). "Consumer report" had the same meaning as in section 603(d) of the Fair Credit Reporting Act (15 U.S.C. 1681(d)). 17 CFR 248.30(b)(1)(i). We are amending the term "consumer report information" currently in Regulation S-P to "consumer information" (without changing the definition) to conform to the term used by other Federal financial regulators in their guidance and rules. *See, e.g.*, 16 CFR 682.1(b) (FTC); 17 CFR 162.2(g) (CFTC); OCC Information Security Guidance at I.C.2.b; FRB Information Security Guidance") at I.C.2.b; FDIC Information Security Guidance at I.C.2.b.

290 As discussed below, the customer information definition also specifies that the definition covers information in the possession of a covered institution or that is handled or maintained by the covered

Commenters did not object to the proposed definition of "customer information." As discussed in the Proposing Release, the customer information definition in the coverage of the safeguards rule is intended to be consistent with the objectives of the GLBA, which focuses on protecting "nonpublic personal information" of those who are "customers" of financial institutions.[291] The customer information definition is also based on the definition of "customer information" in the safeguards rule adopted by the FTC.[292]

Additionally, adding customer information to the coverage of the disposal rule is also consistent with the objectives of the GLBA. Under the GLBA, an institution has a "continuing obligation" to protect the security and confidentiality of customers' nonpublic personal information.[293] The final amendments specify that this obligation continues through disposal of customer information. The final amendments also are consistent with the objectives of the FACT Act, which focuses on protecting "consumer information," a category of information that will remain within the scope of the disposal rule.[294] Adding customer information to the disposal provisions will simplify compliance with the FACT Act by eliminating a covered institution's

---

institution or on its behalf, regardless of whether such information pertains to individuals with whom the covered institution has a customer relationship or the customers of other financial institutions where such information has been provided to the covered institution. This is being adopted substantively as proposed, but reflects structural modifications to the rule text to address the concerns of a commenter who asked for increased clarity. *See infra* section II.B.2 for a discussion of the term customer information with respect to transfer agents.

291 *See* 15 U.S.C. 6801(a).

292 *See* 16 CFR 314.2(d) (The FTC safeguards rule defining "customer information" to mean "any record containing nonpublic personal information, as defined in 16 CFR 313.3(n) about a customer of a financial institution, whether in paper, electronic, or other form, that is handled or maintained by or on behalf of you or your affiliates"). The final amendments do not require covered institutions to be responsible for their affiliates' policies and procedures for safeguarding customer information because covered institutions affiliates generally are financial institutions subject to the safeguards rules of other Federal financial regulators.

293 *See* 15 U.S.C. 6801(a).

294 *See* 15 U.S.C. 1681w(a)(1); proposed rule 248.30(c)(1). "Consumer information" is not included within the scope of the safeguards rule, except to the extent it overlaps with any "customer information," because the safeguards rule is adopted pursuant to the GLBA and therefore is limited to information about "customers."

need to determine whether its customer information is also consumer information subject to the disposal rule. Covered institutions should also be less likely to fail to dispose of consumer information properly by misidentifying it as customer information only. In addition, including customer information in the coverage of the disposal rule would conform the rule more closely to the Banking Agencies' Safeguards Guidance.[295] Commenters did not address the expansion of the disposal rule to cover customer information.

One commenter sought clarification regarding the proposal's coverage of customer information handled or maintained on behalf of a covered institution. This commenter stated that proposed paragraph (a) of rule 248.30, which set out the scope of information collectively covered under the safeguards and disposal rules, could be interpreted to limit the application of the rules to customer information in the possession of the covered institution, while proposed paragraph (e)(5) defined customer information to include information that is handled or maintained on behalf of the covered institution. The proposal included both customer information in the possession of a covered institution as well as customer information handled or maintained on its behalf in both the safeguards and disposal rules. This is because rule 248.30 provided the rules applied to "customer information" and, as the commenter observed, the proposal defined customer information to include "any record containing nonpublic personal information as defined in § 248.3(t) about a customer of a financial institution, whether in paper, electronic or other form, that is handled or maintained by the covered institution or on its

---

[295] *See*, *e.g.*, OCC Information Security Guidance (OCC guidelines providing that national banks and Federal savings associations' must develop, implement, and maintain appropriate measures to properly dispose of customer information and consumer information."); FRB Information Security Guidance (similar Federal Reserve Board provisions for state member banks). *See also* 15 U.S.C. 6804(a) (directing the agencies authorized to prescribe regulations under title V of the GLBA to assure to the extent possible that their regulations are consistent and comparable); 15 U.S.C. 1681w(2)(B) (directing the agencies with enforcement authority set forth in 15 U.S.C. 1681s to consult and coordinate so that, to the extent possible, their regulations are consistent and comparable).

behalf." Applying these rules to information handled or maintained on behalf of a covered institution is necessary so that the incident response program applies to information about a covered institution's customers that is handled or maintained by a service provider on the covered institution's behalf and to require that such information is disposed of properly.

In response to this comment, we have removed the dedicated scope paragraph (a) from the proposed rule and moved all the requirements for customer information and consumer information into the definitions of those terms, now in renumbered paragraphs (d)(5)(1) and (d)(1) respectively. Accordingly, and substantively as proposed, the definition of consumer information covers information that a covered institution maintains or otherwise possesses for a business purpose, and the customer information definition covers information in the possession of a covered institution or that is handled or maintained by the covered institution or on its behalf.[296] These structural changes do not change the scope of the proposed rule, but rather consolidate in each definition the scope of covered information as opposed to referring to information possessed by a covered institution in one paragraph of the rule and referring to information handled on its behalf in another.

[296] We also eliminated language in paragraph (b)(1) that now appears in the final amendments' definitions of customer information and consumer information.

Safeguards Rule and Disposal Rule Coverage of Customer Information

We also are adopting the requirement, substantively as proposed, that both the safeguards rule and the disposal rule apply to the information specified in those definitions regardless of whether such information pertains to (a) individuals with whom the covered institution has a customer relationship or (b) the customers of other financial institutions where such information has been provided to the covered institution.[297] As discussed above, however, we are structurally reflecting this requirement in the definitions of customer information and consumer information, rather than in proposed paragraph (a).

Comments were mixed on expanding the safeguards and disposal rules to cover nonpublic personal information received by covered institutions from third party financial institutions. Some commenters supported the expansion.[298] Two of these commenters stated that sensitive nonpublic information should be protected regardless of how it came into a covered institution's possession.[299] Other commenters opposed the proposed expansion, suggesting that the rules should be limited to the customer information of the covered institution's own customers and stating that the safeguards rule in its current form is appropriately calibrated.[300] One of these commenters stated that requiring notification of customers of other financial institutions under the proposed expansion would be confusing to customers and impractical for covered institutions.[301]

---

297 The safeguards rule is applicable to "consumer information" only to the extent it overlaps with "customer information." *See supra* footnote 291. Regulation S-P defines "financial institution" generally to mean any institution the business of which is engaging in activities that are financial in nature or incidental to such financial activities as described in section 4(k) of the Bank Holding Company Act of 1956 (12 U.S.C. 1843(k)). Rule 248.3(n).

298 *See* EPIC Comment Letter; ICI Comment Letter; Better Markets Comment Letter.

299 *See* ICI Comment Letter; Better Markets Comment Letter.

300 *See* SIFMA Comment Letter 2; CAI Comment Letter.

301 *See* SIFMA Comment Letter 2; *see also supra* footnote 110 and accompanying text.

After considering comments, the final amendments provide that the safeguards rule and disposal rule apply to both nonpublic personal information that a covered institution collects about its own customers and to nonpublic personal information it receives from another financial institution about that institution's customers. Currently, in contrast, Regulation S-P defines "customer" as "a consumer who has a customer relationship with you." The safeguards rule, therefore, only protects the "records and information" of individuals who are customers of the particular institution and not others, such as individuals who are customers of another financial institution. The disposal rule, on the other hand, requires proper disposal of certain records about individuals without regard to whether the individuals are customers of the particular institution. The final amendments better align the scope of the safeguards and disposal rules by requiring that a covered institution protect the information of individuals even if those individuals are not customers of that particular institution but customers of another financial institution.

The amendments also are designed to help ensure that the nonpublic personal information of covered institution customers is better protected from unauthorized disclosure on an ongoing basis, regardless of what entity is maintaining or handling that information.[302] For example, information that a registered investment adviser has received from the custodian of a former client's assets would be covered under both the safeguard and disposal rules if the former client remains a customer of either the custodian or of another financial institution, even though the individual no longer has a customer relationship with the investment adviser.[303] Applying the safeguards rule and the disposal rule to customer information that a covered institution receives

---

302 *See* Proposing Release at the text accompanying nn.156-158.

303 *See* final rule 248.30(d)(5)(i) (customer information is covered by the rule if it pertains to "the customers of other financial institutions where such information has been provided to the covered institution").

from other financial institutions will help ensure customer information safeguards are not lost because a third party financial institution shares that information with a covered institution.

2. Extending the Scope of the Safeguards Rule and the Disposal Rule to Cover All Transfer Agents

As discussed in more detail below, the final amendments, which are the same as proposed except for the modifications to the structure of the rules discussed above,[304] extend both the safeguards rule and the disposal rule to apply to any transfer agent registered with the Commission or another appropriate regulatory agency.[305] We are extending these provisions to transfer agents because, as discussed in the Proposing Release, transfer agents maintain sensitive, detailed information related to securityholders.[306] Like other market participants, systems maintained by transfer agents are subject to threats and hazards to the security or integrity of those systems. Likewise, the individuals whose information is maintained by those transfer agents' systems are subject to similar risks of substantial harm and inconvenience as individuals whose customer information is maintained by other covered institutions. Yet, prior to the amendments, the safeguards rule did not apply to any transfer agents, and the disposal rule applied only to those transfer agents registered with the Commission. To address these risks, and help ensure that individuals whose customer information is held by a transfer agent are protected and receive appropriate notice of a breach in the same manner as individuals whose customer information is held by any other covered institution, the final amendments apply both the safeguards rule and the disposal rule to all transfer agents, even if the transfer agent is registered

---

304 *See supra* section II.B.1 (discussing the changes to the structure of final rule 248.30(d)).

305 The term "transfer agent" is defined by rule 248.30(d)(12) to have the same meaning as in section 3(a)(25) of the Exchange Act (15 U.S.C. 78c(a)(25)).

306 *See* Proposing Release at section II.C.3.